# Intrusion : risques et décisions

Synthèse pour la direction | INC-2026-0302
TLP:AMBER • 10 octobre 2026 • Scénario pédagogique

## Une priorité : protéger les accès et les données

Le dossier décrit une intrusion débutant sur un poste de comptabilité et des activités suspectes sur un serveur de fichiers et le contrôleur de domaine, qui gère les identités de l'entreprise. **Le risque principal concerne l'exposition de données et d'identifiants**, avec un enjeu critique sur le contrôleur de domaine. La présence résiduelle de l'attaquant et le périmètre exact de la compromission restent inconnus.

Un transfert sortant d'environ **2,47 Go** depuis le contrôleur de domaine est signalé comme une exfiltration. Le dossier ne permet pas d'identifier les données envoyées. Aucune interruption de la fourniture d'énergie, atteinte aux systèmes industriels ou opération de rançongiciel n'est démontrée.

## Ce que le dossier permet d'établir

**2 mars :** un document malveillant sur comptabilite-07 lance PowerShell, télécharge une charge et met en place des mécanismes de persistance. Des communications externes sont décrites.

**3 et 4 mars :** balayage interne, session distante suspecte et injection de code sur srv-fichiers-02. Le trajet exact entre les machines n'est pas établi.

**5 au 7 mars :** accès à la mémoire d'authentification sur dc-01, préparation locale de données et transfert sortant important ; contact d'un domaine de repli et effacement du journal de sécurité également rapportés.

## Risques pour les activités de l'entreprise

| Actif / criticité | Conséquence à considérer |
|---|---|
| dc-01<br>Critique | Exposition possible d'identifiants et de données. Un confinement mal préparé pourrait perturber les services dépendant de l'authentification. |
| comptabilite-07<br>Élevée | Point d'entrée compromis ; exposition possible des informations accessibles et maintien d'un accès malveillant. |
| srv-fichiers-02<br>Élevée | Accès distant suspect et injection ; exposition possible de documents partagés. Leur vol n'est pas établi. |

## Décisions recommandées à la direction

**1. Mandater une réponse coordonnée.** Désigner un responsable de crise et réunir le SOC, les équipes de l'annuaire, des postes et des serveurs. Autoriser la conservation des preuves et le confinement des activités suspectes, en préparant les conséquences métier.

**2. Sécuriser les accès et préparer la continuité.** Examiner en priorité dc-01 et les comptes potentiellement exposés ; déterminer les mesures de protection et de renouvellement des accès. Coordonner ces actions avec le confinement du poste de comptabilité et du serveur de fichiers. Vérifier les possibilités de restauration avant toute remise en service.

**3. Établir ce qui a été exposé.** Faire identifier les fichiers, comptes et systèmes concernés, ainsi que les éventuels accès encore actifs. Préserver les journaux et rapprocher les traces réseau des activités sur les hôtes.

**4. Organiser la communication et l'examen réglementaire.** Faire examiner les obligations applicables au scénario d'opérateur d'importance vitale par les fonctions sécurité et juridique, en lien avec l'ANSSI. Les modalités et délais seront détaillés dans la note réglementaire dédiée. Toute communication doit distinguer faits établis, hypothèses et inconnues.

## Attribution : ne pas confondre ressemblance et preuve

**L'acteur reste non identifié.** La piste FIN7 ou d'un utilisateur d'outillage apparenté à Carbanak est possible, avec une confiance faible. Elle repose notamment sur une ressemblance mentionnée dans la fiche d'analyse de la seconde charge ; aucune preuve spécifique ne permet une attribution ferme. La motivation financière n'est pas établie. Les mesures de réponse doivent être guidées par les comportements observés.

## Conditions d'un retour à une situation maîtrisée

La direction devrait demander un bilan indiquant : le périmètre examiné et les actifs encore incertains ; le traitement des accès exposés et de la persistance ; l'état de la collecte des preuves ; les résultats des vérifications de restauration ; les décisions de communication et de déclaration. Une remise en service doit s'appuyer sur ces vérifications, sans assimiler l'absence d'alerte à l'absence d'attaquant.

## Limites et traçabilité

Le dossier pédagogique contient des incohérences concernant le processus Office, la chronologie d'un compte et la date du mémo SOC. Ses fiches, indicateurs, alertes et journaux ne sont pas des confirmations indépendantes. Le contenu transféré, la récupération effective d'identifiants et l'état actuel des systèmes restent inconnus. Les recommandations présentées n'ont pas été exécutées.

Sources : rapport CTI Helios Energy fourni ; fiches BIN-01 à BIN-03 ; 40 indicateurs ; 12 alertes SIEM ; mémo SOC ; journaux bruts. La note d'attribution séparée détaille la piste FIN7/Carbanak et ses sources publiques. Période analysée : 2–7 mars 2026.